

Guía metodológica de la Encuesta FAIR de Ciber-Riesgo

1. Objetivo general

Esta guía acompaña a la encuesta FAIR de ciber-riesgo con el propósito de garantizar que las respuestas sean comparables, interpretables y, dentro de lo humanamente posible, honestas. Se orienta a responsables de seguridad, riesgo, cumplimiento y dirección que deseen evaluar el grado de adopción efectiva de métricas FAIR en su organización.

El objetivo último es disponer de un conjunto de indicadores que permitan: (a) medir la madurez en cuantificación del ciber-riesgo en términos económicos; (b) identificar brechas entre práctica actual y buenas prácticas FAIR; y (c) facilitar la agregación sectorial y nacional de resultados.

2. Marco conceptual

La encuesta se basa en el estándar FAIR (Factor Analysis of Information Risk) y en sus extensiones recientes, incluyendo modelos de eficacia de controles (FAIR-CAM) y de materialidad financiera (FAIR-MAM). Estos marcos definen el riesgo como una combinación de frecuencia probable de eventos de pérdida y magnitud probable de la pérdida, expresadas preferentemente como distribuciones y en unidades monetarias.

Los bloques de preguntas siguen esta lógica: gobernanza, alcance del uso de FAIR, indicadores de frecuencia, indicadores de magnitud, métricas financieras (ALE, percentiles), eficacia de controles, materialidad regulatoria, automatización e IA, integración con continuidad y resiliencia, dimensión sectorial/territorial y reflexión cualitativa final.

3. Diseño de la encuesta

La encuesta está diseñada para ser respondida en aproximadamente 25–35 minutos. Combina preguntas cerradas de elección única o múltiple con algunas preguntas abiertas que permiten capturar matices. La mayoría de ítems se formulan en un tono deliberadamente claro y ligeramente irónico, buscando evitar el síndrome de “todo es excelente” que suele afectar a las autoevaluaciones.

Cada pregunta se ha construido con tres criterios:

1. Alineamiento estricto con conceptos FAIR y su implementación práctica.
2. Relevancia para la construcción de indicadores comparables entre organizaciones y sectores.
3. Capacidad de servir como proxy de madurez sin requerir un tratado de estadística por parte del encuestado.

4. Dimensiones de análisis

4.1 Gobernanza y alineamiento con negocio

Las primeras secciones (datos generales y gobernanza) permiten segmentar los resultados por sector, tamaño y ámbito geográfico, y evaluar el grado de implicación de la alta dirección en la cuantificación del ciber-riesgo. La hipótesis subyacente es que una adopción seria de FAIR se correlaciona con:

- Existencia de políticas formales de cuantificación económica.
- Revisión periódica de resultados cuantitativos por comités directivos o el Consejo.
- Integración de los resultados en decisiones de inversión y apetito de riesgo.

4.2 Alcance y madurez del uso de FAIR

Las preguntas sobre el uso actual de FAIR buscan posicionar a la organización en un continuo que va desde la ignorancia benigna hasta la devoción cuantitativa. El foco está en conocer:

- Si FAIR se utiliza solo en proyectos puntuales o de forma sistemática.
- Si el alcance incluye IT, OT, datos personales, nube y terceros.
- Si los parámetros clave (LEF, LM, TEF, vulnerabilidad) se apoyan en datos o solo en opiniones.

4.3 Indicadores de frecuencia y magnitud

Las secciones dedicadas a frecuencia y magnitud se inspiran directamente en el estándar FAIR y en la literatura reciente sobre cuantificación del riesgo cibernético. El objetivo es saber si la organización:

- Utiliza registros de incidentes y datos de inteligencia de amenazas para estimar frecuencias.
- Emplea distribuciones de probabilidad en lugar de valores puntuales.
- Descompone y valora de forma económica las diferentes formas de pérdida.

En particular, la encuesta pregunta por el tratamiento de pérdidas secundarias (litigios, sanciones, reputación), que suelen ser el pariente pobre de los modelos pese a su relevancia práctica.

4.4 Métricas financieras y comparación con otros riesgos

Las preguntas sobre pérdida anual esperada, percentiles y comparaciones con otros riesgos buscan detectar hasta qué punto FAIR se ha integrado en el lenguaje financiero de la organización. La clave aquí no es sólo “hacer números”, sino compararlos con:

- Ingresos, EBITDA y otros indicadores financieros.
- Niveles de apetito y tolerancia al riesgo.
- Otros riesgos operacionales y financieros, para evitar que el ciber-riesgo viva en una isla.

4.5 Eficacia de controles y FAIR-CAM

La sección de controles explora si la organización sigue midiendo su seguridad en términos de “tener o no tener” controles, o si ha dado el salto a cuantificar su aporte real a la reducción de riesgo. La referencia a FAIR-CAM no exige su adopción literal, pero sí la idea de:

- Definir métricas de capacidad, cobertura y fiabilidad.
- Estimar la reducción de TEF y LM atribuible a cada control o conjunto de controles.

4.6 Materialidad, regulación y reporting

Aquí se examina el vínculo entre FAIR, los requisitos regulatorios (GDPR, NIS2, ENS, regulación sectorial) y los marcos de reporting financiero. Las preguntas se orientan a:

- Detectar si existen criterios de materialidad cuantitativos aplicados a incidentes.
- Estimar el nivel de adaptación de FAIR a las obligaciones de comunicación y reporte.
- Comprender el grado de transparencia frente a reguladores y aseguradoras.

4.7 Automatización, IA e integración con resiliencia

Las secciones finales abordan el grado de automatización del proceso FAIR, el uso de simulación (Monte Carlo) y de IA, y la conexión con continuidad de negocio y resiliencia organizativa. El propósito es identificar si la organización ve FAIR como un ejercicio ocasional o como un proceso vivo apoyado en datos.

5. Escalas de respuesta y codificación

La mayoría de las preguntas utilizan escalas ordinales simples (“no”, “parcialmente”, “sí”) o niveles de madurez (“no existe”, “informal”, “parcial”, “sistemático”). Estas escalas pueden codificarse numéricamente (por ejemplo, 0–3) para construir índices compuestos por dimensión.

Se recomienda:

- Asignar puntuaciones crecientes a los niveles que reflejan mayor madurez, integración con negocio y alineamiento con FAIR.
- Calcular promedios o medianas por sección para generar perfiles de madurez.
- Comparar resultados por sector, tamaño y país cuando la muestra lo permita.

6. Procedimiento de administración

La encuesta está pensada para autoadministración en línea, aunque puede aplicarse también mediante entrevistas estructuradas. Se recomienda que cada organización designe un responsable que coordine las respuestas internas para evitar contradicciones flagrantes entre áreas (por ejemplo, entre TI y Riesgos).

Duración estimada: 25–35 minutos.

Población objetivo: organizaciones medianas y grandes, así como operadores de servicios esenciales, infraestructuras críticas y sectores regulados.

Se recomienda encarecidamente evitar que el proveedor habitual de consultoría responda en nombre de la organización sin participación interna real.

7. Calidad de los datos y sesgos esperables

Dado que la encuesta se basa en autodeclaraciones, es razonable anticipar cierto optimismo antropológico. Los principales sesgos esperables son:

- Sobreestimación de la formalización de procesos.
- Subestimación de la dependencia de juicio experto.
- Confusión entre “tenemos una herramienta” y “usamos bien la herramienta”.

Para mitigar estos efectos se han incluido preguntas que cruzan gobernanza, práctica y resultados (por ejemplo, “se calcula ALE” vs “se presenta ALE al Consejo”). En el análisis, resultará útil identificar incoherencias internas como indicador indirecto de madurez.

8. Uso de resultados

Los resultados pueden utilizarse en tres niveles:

4. Organizativo: para elaborar un informe interno de madurez FAIR, priorizar mejoras y justificar inversiones.
5. Sectorial: para que asociaciones profesionales y reguladores entiendan la distribución de capacidades y diseñen políticas basadas en evidencia.
6. Nacional: para alimentar modelos agregados de pérdida esperada por ciber-riesgo y orientar estrategias de resiliencia.

En todos los casos, es recomendable acompañar los hallazgos cuantitativos con un análisis cualitativo breve, especialmente cuando los números parezcan demasiado buenos para ser ciertos.

9. Consideraciones éticas y de confidencialidad

La información obtenida mediante la encuesta puede resultar sensible, especialmente cuando se cruza con datos financieros o de incidentes. Por ello, se recomienda:

- Anonimizar las respuestas en los análisis agregados.
- Evitar la publicación de resultados individuales identificables.
- Establecer acuerdos claros sobre el uso de datos con las organizaciones participantes.

En resumen, la encuesta no pretende servir como prueba incriminatoria, sino como espejo razonablemente honesto del estado de la cuantificación del ciber-riesgo. Lo que cada organización decida hacer después de mirarse en él ya entra en el terreno, siempre resbaladizo, de la gobernanza.